

INTERN DOCUMENT — niet publiceren. Bewaren zolang de verwerking plaatsvindt.

AVG art. 33/34 — intern document — 4 juli 2026

Verwerkingsverantwoordelijke: Dennis van Westbroek · KVK 74667653 · info@perfectsupplement.nl

Datalekprocedure — PerfectSupplement.nl

Versie 1.0 — 4 juli 2026

Intern document — gebruik bij (vermoeden van) een datalek

Verwerkingsverantwoordelijke: Dennis van Westbroek · KVK 74667653 · info@perfectsupplement.nl

Uitgebreide context en risicobeoordeling: docs/core/DPIA.md §4.1. Dit document is de **praktische one-pager** voor acute situaties.

Wanneer is dit van toepassing?

Een **datalek** = een beveiligingsincident waarbij persoonsgegevens verloren gaan, worden gestolen, per ongeluk worden gewijzigd of ongeoorloofd worden ingezien.

Voorbeelden bij PerfectSupplement:

- Ongeautoriseerde toegang tot Supabase-intake-data (gezondheidsgegevens)
- Verkeerd geadresseerde e-mail met profiel-snapshot of recovery-link
- Gelekt server-/API-geheim waardoor sessies leesbaar worden
- Verwerker meldt incident (Supabase, Resend, Cloudflare, etc.)

Bij twijfel: **start altijd deze procedure**. Liever een melding te veel dan te laat.

Wie doet wat?

Rol	Wie	Actie
Eerste meldpunt	Dennis van Westbroek	info@perfectsupplement.nl — alles wat op een lek lijkt komt hier binnen
Incidentleider	Dennis van Westbroek	Coördineert beoordeling, AP-melding, communicatie
Technisch	Dennis van Westbroek	Server/Supabase/logs, containment, herstel
Extern advies	Optioneel privacy-advocaat	Bij gezondheidsdata of onduidelijk risico

Bij afwezigheid: e-mail blijft actief; geen tweede persoon vereist (eenmanszaak).

Stappenplan (art. 33 en 34 AVG)

Stap 1 — Constateren en containen (uur 0)

- ☐ Stop verdere lekkage (API-key roteren, account sluiten, endpoint blokkeren)
- ☐ Noteer: **datum/tijd ontdekking**, wie ontdekte het, wat is zichtbaar
- ☐ Bewaar logs/screenshots (geen PII in Slack/e-mail naar derden)

Stap 2 — Beoordelen (binnen 24 uur)

Beantwoord deze vragen:

Vraag	Invullen
Welke gegevens?	Bijv. intake-antwoorden, e-mail, scores, IP-hash
Bijzondere gegevens (art. 9)?	Ja/nee — gezondheidsdata = hoger risico
Hoeveel betrokkenen (schatting)?	
Wat is de waarschijnlijke impact?	Identiteitsdiefstal, stigma, geen impact, ...
Is lek nog gaande?	Ja/nee

Besluit:

- **Geen risico** voor rechten/vrijheden → documenteer intern, geen AP-melding
- **Risico** → stap 3 (AP binnen 72 uur)
- **Hoog risico** → stap 3 + stap 4 (betrokkenen informeren)

Stap 3 — Melding Autoriteit Persoonsgegevens (binnen 72 uur)

Alleen als stap 2 risico oplevert.

- **Portaal:** meldportaal.autoriteitpersoonsgegevens.nl
- **Inhoud:** aard van het lek, categorieën gegevens, geschat aantal personen, waarschijnlijke gevolgen, genomen maatregelen, contactgegevens

Deadline = **72 uur na ontdekking**, niet na oplossing.

Stap 4 — Betrokkenen informeren (alleen bij hoog risico, art. 34)

- Via e-mail naar getroffen adressen (uit Supabase, alleen als veilig te gebruiken)
- Duidelijke taal: wat er gebeurde, welke gegevens, wat ze kunnen doen, contact voor vragen
- Geen copy-paste van medische details in de melding

Stap 5 — Afsluiten en leren

- ☐ Incidentlog bijwerken (zie onder)
- ☐ Verwerker informeren indien hun fout (zie contacten)
- ☐ Maatregel om herhaling te voorkomen
- ☐ Verwerkingsregister/DPIA bijwerken als verwerking wijzigt

Incidentlog (bewaren 5 jaar)

Veld	Waarde
Incident-ID	INC-YYYY-MM-DD-01
Ontdekt op	
Gemeld AP op	ja/nee — referentie
Betrokkenen geïnformeerd	ja/nee — datum
Categorie gegevens	
Aantal betrokkenen (schatting)	
Oorzaak	
Maatregelen	
Afgesloten op	

Bewaar in: Documenten/documenten/perfectsupplement/privacy/incidenten/ (map aanmaken bij eerste incident).

Verwerker-contacten (datalek bij leverancier)

Verwerker	Melden via
Supabase	supabase.com/support — dashboard + security e-mail in DPA
Hetzner	Abuse/security via Hetzner Console
Cloudflare	Dashboard → Support; security@cloudflare.com bij actief incident
Resend	support@resend.com
Google (Analytics)	Google account security; data protection contact via Google Ads/Analytics terms
Microsoft (Clarity)	Via Microsoft 365 admin / DPA contact

Verwerker	Melden via
Zoho CRM	Zoho support / privacy contact in admin

Controleer in je DPA-archief of er een specifiek security-e-mailadres staat.

Sjabloon e-mail aan betrokkenen (art. 34)

`` Onderwerp: Belangrijke mededeling over je gegevens bij PerfectSupplement

Beste [voornaam],

We nemen contact met je op omdat er een beveiligingsincident heeft plaatsgevonden waarbij gegevens uit onze leefstijlcheck mogelijk in verkeerde handen zijn gekomen.

Wat er is gebeurd: [korte feitelijke omschrijving] Welke gegevens dit kan betreffen: [bijv. e-mailadres en intake-antwoorden] Wat we hebben gedaan: [maatregelen] Wat je kunt doen: [bijv. wachtwoord wijzigen elders, toestemming intrekken via perfectsupplement.nl/privacy]

Vragen? Mail info@perfectsupplement.nl

Met vriendelijke groet, Dennis van Westbroek PerfectSupplement ``

Noodnummers & links

AP meldportaal	https://meldportaal.autoriteitpersoonsgegevens.nl
AP algemeen	https://www.autoriteitpersoonsgegevens.nl
Intern contact	info@perfectsupplement.nl
Toestemming intrekken (site)	https://perfectsupplement.nl/privacy

Dit document intern houden. Niet publiceren op de website.